

Phase 3: Vulnerability

Assessment Report

Target: **139.59.2.14**

Assessment Phase: **Vulnerability Assessment and Penetration Testing (VAPT)**

Report Type: **Comprehensive Vulnerability Assessment**

Date: **October 11, 2025**

Team Members and Access Details:

1. Devika G

- Public IP: 111.92.61.232
- Tools Used: IPVoid, VirusTotal, Shodan, Censys

2. Vaishnav K.R

- Public IP: 106.76.186.122
- Tools Used: Gobuster, Nikto, WhatWeb

3. Aswin Suresh

- Public IP: 202.83.36.228
- Tools Used: Nmap, Netcat (nc), Dig, Dnsrecon

Index

1. Summary & Scope	3
2. Methodology & Recon Mapping	4
3. Vulnerability Distribution & Posture	5
4. Vulnerability Catalog	4
4.1 Critical Vulnerabilities	4
4.2 High & Medium Vulnerabilities	6
5. Evidence Appendix	7
6. Remediation Roadmap	9
7. Conclusion	10
8. References	10

1. Summary & Scope

This assessment covers host **139.59.2.14**, evaluating nine open TCP services (FTP, SSH, DNS, HTTP×3, LDAP, NFS, MariaDB). Automated scans (Nessus Essentials, Nmap, Nikto, Gobuster, WhatWeb) and manual techniques (curl, nc, ldapsearch, showmount, rpcinfo) identified **21 vulnerabilities**: 7 Critical, 3 High, 6 Medium, 5 Low. Immediate remediation of EOL software and unsafe configurations is required to reduce exploitation risk.

2. Methodology & Recon Mapping (page 4)

Phase 1 Method	Phase 2 Findings	Phase 3 Usage
Network Enumeration (Nmap)	Discovered open ports and services	Targeted service/version discovery
Banner Grabbing (curl, nc)	Identified software versions	Confirmed version info for vulnerabilities
Web Enumeration (Gobuster)	Found application paths (phpMyAdmin)	Validated with directory brute-force
Web Vulnerability Scans	Preliminary header/config gaps	Detailed via Nikto
LDAP Enumeration (ldapsearch)	RootDSE namingContext	Verified anonymous bind and base DN
NFS Enumeration (showmount)	No exports visible	Confirmed export restrictions

3. Vulnerability Distribution & Posture

Severity Distribution

Severity	Count
Critical	7
High	3
Medium	6
Low	5

Overall Posture:

The host is in a **critical security state**: multiple EOL software versions, serious web misconfigurations, and high-severity vulnerabilities. Exposed administration interfaces and unsafe HTTP methods exacerbate risk. Immediate remediation is imperative.

4. Vulnerability Catalog

4.1 Critical Vulnerabilities

ID	Vulnerability	CVE(s)	CVSS	Evidence Command & Output
C1	PHP 5.6.40 RCE via crafted requests	CVE-2019-11043	9.8	<pre>bash
curl -I http://139.59.2.14:54444
` ``````\nHTTP/1.1 400 Bad Request\nServer: Apache/2.4.38 ... PHP/5.6.40 ...\n</pre>

C 2	EOL PHP—no security patches since 2018	N/A	10. 0	Banner above; no further patches available
C 3	Apache 2.4.38 < 2.4.54 multiple RCE/DoS	CVE- 2021 -392 75, CVE- 2021 -347 98	9.8	Nessus Plugin 128033: "Apache 2.4.x < 2.4.41 Multiple Vulnerabilities" (see appendix)
C 4	OpenSSL 1.0.2q buffer over-read memory leak	CVE- 2024 -553 5	9.1	Nessus OpenSSL findings (appendix)
C 5	HTTP TRACE method enabled (XST)	N/A	8.0	bash nikto -h http://139.59.2.14:56686 ` `` `` `` `` `` \n+ TRACE method allowed\n
C 6	phpMyAdmin directory exposure	N/A	8.5	bash gobuster dir -u http://139.59.2.14 -w common.txt ` `` `` `` `` `` \n/phpmyadmin (301) -> /phpmyadmin/\n

C 7	Directory indexing on /tmp/ and /icons/	N/A	7.5	bash nikto -h http://139.59.2.14:56686 ` ``````\n+ /tmp/ directory indexing\n+ /icons/ directory indexing\n
--------	---	-----	-----	---

4.2 High & Medium Vulnerabilities

ID	Vulnerability	CVE (s)	CVSS	Evidence
H 1	Missing X-Frame-Options header	N/A	6.5	bash nikto -h http://139.59.2.14
H 2	Missing X-Content-Type-Options header	N/A	6.5	Same as above
H 3	mod_negotiation MultiViews enabled	N/A	6.0	bash nikto -h http://139.59.2.14:56686
M 1	FTP banner/version info disclosure	N/A	5.5	bash nc -nv 139.59.2.14 21 ` ``````\n220 ubuntu-... FTP server (Version 6.4/OpenBSD...) ready.\n
M 2	Anonymous LDAP bind allowed	N/A	5.0	bash ldapsearch -x -H ldap://139.59.2.14:389 -b "" -s base namingContexts ` ``````\nnamingContexts : dc=nodomain\n

5. Evidence Appendix

5.1 cURL Header Outputs

```
curl -I http://139.59.2.14:80
```

```
HTTP/1.1 200 OK
```

```
Server: Apache/2.4.41 (Ubuntu)
```

```
ETag: "2aa6-5e3c7fdbe936f"
```

```
curl -I http://139.59.2.14:54444
```

```
HTTP/1.1 400 Bad Request
```

```
Server: Apache/2.4.38 (Unix) OpenSSL/1.0.2q PHP/5.6.40
```

```
mod_perl/2.0.8-dev Perl/v5.16.3
```

```
curl -I http://139.59.2.14:56686
```

```
HTTP/1.1 200 OK
```

```
X-Powered-By: PHP/5.6.40
```

5.2 Gobuster Output

```
gobuster dir -u http://139.59.2.14 -w
```

```
/usr/share/wordlists/dirb/common.txt
```

```
/.htaccess (Status: 403)
```

```
/phpmyadmin (Status: 301) -> /phpmyadmin/
```

```
/index.html      (200)
/javascript      (301)
/server-status   (403)
```

5.3 Nikto Scan Snippets

```
nikto -h http://139.59.2.14
```

```
+ Missing X-Frame-Options header
+ Missing X-Content-Type-Options header
```

```
nikto -h http://139.59.2.14:56686
```

```
+ TRACE method allowed
+ /tmp/ directory indexing
+ /icons/ directory indexing
```

5.4 Nmap Enumeration

```
nmap -sV -p 21,22,53,80,389,2049,53346,54444,56686 139.59.2.14
```

```
21/tcp    open  ftp      OpenBSD ftpd 6.4
80/tcp    open  http     Apache httpd 2.4.41
54444/tcp open  http     Apache 2.4.38 ... PHP/5.6.40
56686/tcp open  http     Apache 2.4.38 ... PHP/5.6.40
389/tcp   open  ldap     OpenLDAP 2.3
2049/tcp   open  nfs      3-4 (RPC #100003)
53346/tcp open  mysql    MariaDB 10.3.23 (unauthorized)
```

6. Remediation Roadmap

Immediate (0–7 days):

- Upgrade PHP to v8.1+, Apache to $\geq 2.4.54$, OpenSSL to $\geq 3.0.7$.
- Disable HTTP TRACE:

```
TraceEnable off
```

- Restrict or remove public phpMyAdmin access.
- Disable directory indexing:

```
<Directory "/var/www/html/tmp">  
    Options -Indexes  
</Directory>
```

Short Term (7–30 days):

- Implement security headers:

```
Header always set X-Frame-Options "SAMEORIGIN"  
Header always set X-Content-Type-Options "nosniff"
```

- Remove deprecated modules (mod_perl, EOL PHP).

Medium Term (30–90 days):

- Deploy WAF for web apps.
 - Automate monthly patch cycles.
 - Monitor logs for unusual HTTP methods or errors.
-

7. Conclusion

The assessment confirmed a **critical security posture**, driven by unsupported EOL components, exploitable HTTP methods, directory exposures, and admin interfaces accessible without adequate controls. Urgent remediation, as outlined, will significantly reduce attack surface and risk of remote exploitation.

8. References

CVE References:

- CVE-2019-11043: <https://nvd.nist.gov/vuln/detail/CVE-2019-11043>
- CVE-2021-39275: <https://nvd.nist.gov/vuln/detail/CVE-2021-39275>
- CVE-2021-34798: <https://nvd.nist.gov/vuln/detail/CVE-2021-34798>
- CVE-2024-5535: <https://nvd.nist.gov/vuln/detail/CVE-2024-5535>
- CVE-2016-2183 (SWEET32): <https://nvd.nist.gov/vuln/detail/CVE-2016-2183>

Tool Documentation:

- Nmap: <https://nmap.org/>
- Gobuster: <https://github.com/OJ/gobuster>
- Nikto: <https://cirt.net/Nikto2>
- WhatWeb: <https://morningstarsecurity.com/research/whatweb>
- Nessus Essentials:
<https://www.tenable.com/products/nessus/nessus-essentials>

Methodology:

- OWASP Testing Guide:
<https://owasp.org/www-project-web-security-testing-guide/>